

15/04/2026

Azure Cloud

מעבדה 3

חקירת URLs חשודים — Microsoft Defender for Office 365

פישניג ואבטחת מייל — שימוש ב-Safe Links, Threat Explorer ו-URL Detonation

מטרות המעבדה

- שימוש ב-Microsoft Defender Threat Explorer לחקירת URLs חשודים
- ניתוח דוחות Safe Links — זיהוי קליקים על קישורים מסוכנים
- הבנת URL Detonation — סריקה אוטומטית של קישורים ב-sandbox
- חקירת URL Clicks בזמן אמת וזיהוי משתמשים שנחשפו
- הגדרת מדיניות Safe Links מותאמת
- ייצוא IOCs מ-Threat Explorer לצורך blocking

דרישות מקדימות

- רישיון Microsoft Defender for Office 365 Plan 1 או Plan 2
- גישה ל-Microsoft 365 Defender Portal — security.microsoft.com
- הרשאות Security Administrator או Security Reader
- Safe Links policy מוגדרת (ברוב הארגונים מוגדרת כברירת מחדל)
- דפדפן מודרני (Edge / Chrome)

רקע תיאורטי — URL Detonation ו-Safe Links

Microsoft Safe Links — איך זה עובד?

Safe Links הוא מנגנון של Microsoft Defender for Office 365 שמבצע:

- **URL Rewriting** — כל URL במייל נכנס נעטף בקישור של Microsoft:

`...=https://nam01.safelinks.protection.outlook.com/?url`

- **Time-of-Click Verification** — כאשר משתמש לוחץ על הקישור, Microsoft בודקת אותו בזמן אמת (לא רק בזמן קבלת המייל)

- **URL Detonation** — קישורים חשודים מורצים ב-Sandbox לזיהוי תוכן זדוני (JavaScript (redirect, credential harvesting, malware download

- **Click Tracking** — כל קליק מתועד, כולל: מי לחץ, מתי, מאיפה, והאם ה-URL חסום

URL Detonation פותח את ה-URL בסביבת sandbox וירטואלית ובודק:

- האם הדף מבצע redirect לאתר זדוני

- האם יש טופס credential harvesting

- האם הדף מוריד קבצים אוטומטית

- האם יש JavaScript מעורפל (obfuscated)

- האם האתר מתחזה למותג מוכר (Brand Impersonation)

חלק א — חקירת URLs ב-Threat Explorer

שלב 1

היכנסו ל-Microsoft 365 Defender Portal:

```
https://security.microsoft.com  
→ Email & Collaboration → Explorer
```

Threat Explorer הוא הכלי המרכזי לחקירת איומי מייל בזמן אמת.

שלב 2

בחרו את תצוגת **URL Clicks** מהתפריט העליון:

```
Explorer → View: URL clicks
```

הגדירו את טווח הזמנים: 7 ימים אחרונים.

התצוגה מציגה טבלה של כל הקליקים על URLs עם:

URL — הקישור שנלחץ

Click verdict — Allowed / Blocked / PendingDetonation / ErrorPage

User — המשתמש שלחץ

Click time — זמן הקליק

Workload — Email / Teams / Office Documents

סננו לפי **Click verdict = Blocked** כדי לראות URLs שנחסמו בזמן אמת.

שלב 3

סננו לפי URLs מסוכנים שזוהו:

Explorer → View: All email

→ Add filter: URL domain → Contains → "login" OR "verify" OR "secure"

→ Add filter: Delivery action → Delivered to junk / Quarantined

סינון זה מאתר מיילים עם URLs שמכילים חילות מפתח נפוצות בפשינג.

שלב 4

לחצו על URL ספציפי כדי לפתוח את **URL Entity Page**:

דף זה מציג מידע מקיף על ה-URL:

Verdict: Phish / Malware / Safe / Unknown

Detection Technology: URL detonation / URL reputation / Brand impersonation

First seen / Last seen: מתי ה-URL זוהה לראשונה

Click count: כמה משתמשים לחצו

Related emails: באילו מיילים ה-URL הופיע

Detonation details: תוצאות הרצה ב-Sandbox (screenshots, verdicts)

ה-URL Entity Page מספק תמונה מלאה של הסיכון — כמה משתמשים נחשפו, מאיזה מיילים, ומה המערכת גילתה.

שלב 5

URL Entity Page → Detonation tab

Detonation verdict: Phish

Screenshot: [המזויף login-תמונת מסך של דף ה]

Final URL: <https://evil-phish.com/microsoft-login.html>

(After 3 redirects from original URL)

Behavior:

- JavaScript redirect detected
- Credential harvesting form identified
- Microsoft logo brand impersonation
- SSL certificate: self-signed

ה-Sandbox גילה שה-URL מבצע 3 redirects ומגיע לדף login מזויף של Microsoft — זהו
!credential harvesting

חלק ב — ניתוח Safe Links Reports

שלב 1

פתחו את דוח **URL Protection**:

Security Portal → Reports → Email & collaboration → URL protection report

הדוח מציג סיכום של כל פעילות Safe Links:

URL click by verdict: Allowed / Blocked / Error פילוח לפי

URL click by application: Email / Teams / Office

Top clicked URLs: ה-URLs שנלחצו הכי הרבה

Top targeted users: המשתמשים שלחצו על הכי הרבה URLs חסומים

שלב 2

בדקו את **Top Targeted Users** — משתמשים שנחשפו הכי הרבה:

URL protection report → Details table → Sort by: Blocked clicks (high to low)

דוגמה לתוצאה:

Override clicks	קליקים חסומים	קליקים מותרים	משתמש
3	12	45	user1@company.com
0	8	38	user2@company.com
2	7	22	cfo@company.com

Override clicks = המשתמש עקף את האזהרה ולחץ בכל זאת! אלו משתמשים שדורשים הדרכה מיוחדת.

שלב 3

בדקו את **Threat Protection Status** report

Reports → Threat protection status → View data by: URL phishing
→ Filter: Date range = Last 30 days

הדוח מציג:

- מגמות של URL phishing לאורך זמן
- טכנולוגיות זיהוי: URL reputation, Detonation, Brand impersonation
- פעולות שננקטו: Blocked, Quarantined, Delivered

שלב 4

ייצוא נתונים לניתוח חיצוני:

Explorer → URL clicks view → Export → Download CSV

ה-CSV כולל את כל הקליקים עם פרטים מלאים. פתחו ב-Excel וצרו Pivot Table:

- **Rows:** URL Domain
- **Columns:** Click Verdict

Pivot Table מאפשר לזהות דומיינים שמופיעים שוב ושוב — סימן לקמפיין פשינג מתמשך.

חלק ג — חקירת אירוע URL בזמן אמת

שלב 1

תרחיש: התקבלה התראה שמשתמש לחץ על URL חשוד. בצעו חקירה מלאה.

פתחו **Threat Explorer** וחפשו את ה-URL:

```
Explorer → All email view
→ Filter: URL contains "login-verify-account.com"
→ Date range: Last 24 hours
```

שלב 2

זהו את כל המיילים שהכילו את ה-URL:

בתוצאות תראו:

```
Results:
Email 1: From: security@microsoft-verify.com
        Subject: "Action Required: Verify Your Account"
        Recipients: 15 users
        Delivery: 12 Delivered, 3 Quarantined

Email 2: From: noreply@microsoft-verify.com
        Subject: "Your Account Will Be Suspended"
        Recipients: 8 users
        Delivery: 5 Delivered, 3 Blocked
```

זהו קמפיין פשינג — 23 מיילים ל-23 משתמשים שונים מאותו דומיין זדוני!

שלב 3

בדקו מי מהמשתמשים לחץ על ה-URL:

URL Entity Page → URL clicks tab

Clicked by:

user1@company.com - 2026-04-15 09:15:22 - Blocked (warning page shown)
user3@company.com - 2026-04-15 09:18:45 - Blocked (warning page shown)
cfo@company.com - 2026-04-15 09:22:11 - Override (user clicked through)
user7@company.com - 2026-04-15 10:01:33 - Blocked

cfo@company.com עקף את האזהרה! זה דורש תגובה מיידיית — ייתכן שפרטי הגישה נגנבו.

שלב 4

בצעו **Remediation** — הסרת המיילים מתיבות המשתמשים:

Explorer → סמנו את כל המיילים הקשורים
→ Actions → Move to: Deleted Items
או: Hard Delete (מחיקה לצמיתות)
או: Soft Delete (ניתן לשחזר)

בחרו ב-**Soft Delete** כברירת מחדל. ניתן לשחזר אם מתברר שהמייל לגיטימי.

Remediation מסיר את המיילים מכל התיבות — גם אלו שכבר נקראו. פעולה זו מונעת קליקים נוספים.

שלב 5

סמנו את ה-URL וה-Sender ב-Tenant Allow/Block List:

Security Portal → Policies & Rules → Threat Policies
→ Tenant Allow/Block Lists → URLs tab → + Block

Block URL: *login-verify-account.com*
Block Sender: microsoft-verify.com

Notes: Phishing campaign targeting company employees
Expiration: 90 days

מעטה כל מייל שמכיל URL מדומיין זה או שנשלח מדומיין זה — יחסם אוטומטית.

שלב 6

צרו **Incident Report** מהנתונים שאספתם:

Incident Summary:

Date: 2026-04-15

Type: Phishing Campaign – Credential Harvesting

IOCs:

- Domain: login-verify-account.com
- Domain: microsoft-verify.com
- URL: hxxps://login-verify-account[.]com/ms-auth/login.php
- Sender IPs: 185.234.72.19, 91.215.85.33

Impact:

- 23 users received phishing emails
- 4 users clicked the URL
- 1 user (CFO) overrode the warning – potential credential compromise

Actions Taken:

- Emails removed from all mailboxes (Soft Delete)
- Domain and URL blocked in Tenant Allow/Block List
- CFO account: password reset initiated, MFA verified
- IT Security notified

חלק ד — הגדרת Safe Links Policy מותאמת

שלב 1

נווטו להגדרות Safe Links:

Security Portal → Policies & Rules → Threat Policies → Safe Links

בדקו את המדיניות הקיימת (Built-in protection) ולחצו **Create** ליצירת מדיניות מותאמת.

שלב 2

הגדרות מומלצות למדיניות Safe Links:

"Name: "Enhanced Safe Links - VIP Users

Users and domains: בחרו את קבוצת ה-VIP users

הגדרות URL:

Action for potentially malicious URLs in emails:

- ✓ On: Safe Links checks a list of known, malicious links when users click
- ✓ Apply Safe Links to emails sent within the organization
- ✓ Apply real-time URL scanning for suspicious links and links that point to external domains
- ✓ Wait for URL scanning to complete before delivering the message
- ✓ Do not rewrite URLs, do checks via Safe Links API only

Action for potentially malicious URLs in Microsoft Teams:

- ✓ On: Safe Links checks a list of known, malicious links when users click

Click protection settings:

- ✓ Track user clicks
- ✓ Let users click through to the original URL (UNCHECK for VIP!)
- ✓ Display the organization branding on notification and warning pages

עבור משתמשי VIP (CEO, CFO, מנהלים בכירים), **בטלו** את "Let users click through" — כך הם לא יוכלו לעקוף את האזהרה!

שלב 3

הגדירו רשימת **Do not rewrite URLs** (אם נדרש):

Safe Links policy → Do not rewrite the following URLs:

- https://internal-app.company.com/*
- https://trusted-partner.com/portal/*

הוסיפו כאן רק URLs פנימיים שאתם סומכים עליהם לחלוטין. כל URL אחר ייבדק.

שלב 4

הפעילו את המדיניות ובדקו שהיא חלה:
שלחו מייל ניסיון עם קישור ובדקו שה-URL נעטף:

```
# מקורי במייל URL:  
https://example.com/test-page  
  
# URL לאחר Safe Links rewriting:  
https://nam01.safelinks.protection.outlook.com/?url=https%3A%2F%2Fexample.
```

אם ה-URL נעטף — Safe Links פעיל ומגן על המשתמשים.

חלק ה — שימוש ב-Advanced Hunting לחקירת URLs

שלב 1

פתחו **Advanced Hunting** לשאילתות KQL מתקדמות:

```
Security Portal → Hunting → Advanced Hunting
```

שלב 2

שאילתה לזיהוי כל הקליקים על URLs חסומים ב-7 ימים אחרונים:

```
UrlClickEvents  
| where Timestamp > ago(7d)  
| where ActionType == "ClickBlocked"  
| summarize ClickCount = count() by Url, AccountUpn
```

```
| sort by ClickCount desc  
| take 20
```

שלב 3

שאילתה לזיהוי משתמשים שעקפו אזהרות Safe Links:

```
UrlClickEvents  
| where Timestamp > ago(30d)  
| where IsClickedThrough == true  
| summarize OverrideCount = count() by AccountUpn  
| sort by OverrideCount desc  
| take 10
```

משתמשים שעוקפים אזהרות באופן קבוע הם סיכון אבטחתי — יש לתת להם הדרכה ממוקדת.

שלב 4

שאילתה לזיהוי קמפיין פישיוג — URLs מאותו דומיין:

```
EmailUrlInfo  
| where Timestamp > ago(7d)  
| where Url has "login" or Url has "verify" or Url has "secure" or Url has  
| extend UrlDomain = tostring(parse_url(Url).Host)  
| summarize EmailCount = dcount(NetworkMessageId),  
              RecipientCount = dcount(RecipientEmailAddress)  
              by UrlDomain  
| where EmailCount > 5  
| sort by EmailCount desc
```

שאילתה זו מזהה דומיינים שמופיעים ביותר מ-5 מיילים שונים — סימן לקמפיין מאורגן.

שלב 5

שאילתה משולבת — URLs ותוצאות Email Authentication:

```

EmailEvents
| where Timestamp > ago(7d)
| where EmailDirection == "Inbound"
| where AuthenticationDetails has "dmarc=fail" or AuthenticationDetails has "spf=fail"
| join kind=inner (
    EmailUrlInfo
    | where Timestamp > ago(7d)
) on NetworkMessageId
| project Timestamp, SenderFromAddress, RecipientEmailAddress, Subject, Url
| take 50

```

שאיילתה זו מחברת בין מיילים שנכשלו באימות לבין ה-URLs שהכילו — IOCs בעלי ערך גבוה.

תוצאה צפויה

לאחר השלמת המעבדה תוכלו:

- להשתמש ב-Threat Explorer לחקירת URLs חשודים
- לנתח Safe Links reports ולזהות משתמשים בסיכון
- לבצע URL Detonation analysis ולהבין את ממצאי ה-Sandbox
- לבצע Remediation — הסרת מיילים זדוניים מכל התיבות
- לחסום URLs ודומיינים ב-Tenant Allow/Block List
- לכתוב שאילתות KQL ב-Advanced Hunting לחקירת URLs
- להגדיר Safe Links policy מותאמת למשתמשי VIP

שאלות לניתוח

1. מדוע Safe Links בודק URLs "בזמן הקליק" ולא רק "בזמן קבלת המייל"? מה היתרון?
2. מהם הסיכונים כאשר משתמש עוקף (Override) את אזהרת Safe Links? כיצד תמנעו זאת?
3. כיצד URL Detonation מזהה Credential Harvesting? אילו סימנים ה-Sandbox מחפש?
4. מהו ההבדל בין Soft Delete ל-Hard Delete בביצוע Remediation? מתי תשתמשו בכל אחד?
5. ארגון גילה שקמפיין פשיג שלח 100 מיילים ל-100 משתמשים שונים. כיצד תבדקו כמה מהם לחצו על ה-URL?
6. מדוע חשוב לחסום את הדומיין ולא רק את ה-URL הספציפי?

סיכום

במעבדה זו למדנו כיצד לחקור URLs חשודים בסביבת Microsoft 365. Threat Explorer מספק תצוגה מקיפה של כל URL שעובר דרך המערכת. Safe Links מגן בזמן אמת ומונע גישה לאתרים מסוכנים. URL Detonation מריץ קישורים ב-Sandbox ומזהה credential harvesting, malware downloads ו-brand impersonation. Advanced Hunting (KQL) מאפשר שאילתות מתקדמות לזיהוי דפוסים וקמפיינים. שילוב של כל הכלים הללו מספק יכולת חקירה ותגובה מהירה לאיומי פישניג מבוססי URL.